PECB

CASE STUDY

e-Scooter

CERTIFIED ISO/IEC 27001 LEAD IMPLEMENTER TRAINING COURSE

Table of Contents

I. Company Background

e-Scooter is a private company, headquartered in Paris, France, provides electric scooter sharing services since 2017. Noticing the increasing use of electric motorized scooters in the US, Marc Leroux founded his company aiming to introduce electric scooters all around Europe. Initially, *e-Scooter* launched its scooter-sharing system in Paris, with 750 e-scooters being trialled for the first time, then expanded to other major European cities, such as London, Madrid, Berlin, Rome, and Istanbul.

The use of e-scooters in these cities increased as people preferred using fast and convenient modes of transportation. The possibility to locate and park scooters at any corner and the low charges for the services made the entire experience even more enjoyable for the customers. In order to use one of the company's electric scooters, customers had to download the *e-Scooter* application. Through the application, the customers could locate the nearest scooter and unlock it by scanning its QR code. The start-up price for unlocking the scooter was $1, adding 20 cents per minute to the final price.

In addition, the customers also liked the flexibility that was offered by *e-Scooter* for paying for the company's services. *e-Scooter* enabled its customers to pay both online and in cash. For those who preferred digital transactions, customers had the option to enter their personal information and make payments directly through their bank accounts via the e-Scooter application. Alternatively, for those who preferred to pay in cash, *e-Sooter* integrated a phone number-based payment system into the application. Thus, with just a few steps, customers could enter their phone number and be redirected to a website displaying nearby locations where they could conveniently make cash payments.

e-Scooter has developed its payment service in cooperation with *BankIT* (a company that offers specialized customizable software for financial technology companies). All the services that *BankIT* has offered to *e-Scooter* were available in a single platform that handles the payment process, including the security required to operate such a platform.

e-Scooter prioritizes safety and sustainability, the well-being of its employees, and the implementation of eco-friendly practices. Through these practices, the company has managed to reach millions of users around Europe and to become a top competitor in the scooter-sharing industry in the world reaching a net worth of $200 million.

II. Recent Events

As the company experienced a rapid growth in revenue during the years, its pressure to stand out in the market and provide qualitative services for its customers grew, as well. To decrease production costs, maximize the production capacities, and increase profits, the top management of *e-Scooter* decided to outsource the production of the electric scooters to *LING*, a private company in China.

Although the company made promising changes, it continued to face new issues and challenges that required innovative solutions to maintain its position as a leader in the scooter-sharing industry. One of the issues was the abandonment of the scooters by the customers in areas such as lakes or rivers, which made the retrieval of the scooters very difficult. This posed environmental concerns but also made the process of retrieving the scooters time-consuming and expensive for the company.

Another issue was that the scooters were being easily stolen because of their light weight and because the alarm would not go off if someone took the scooter and did not unlock it. After being stolen, the electric scooters' board would be replaced with another board and their GPS would be removed so that the company would not be able to locate them.

Furthermore, because the company used QR scanning stickers to enable the customers to use the e-scooters, the risk for cyberattacks was quite high. That is because attackers could easily replace the e-scooter's QR codes with stickers that consisted of fabricated QR codes and that comprised malicious URLs. These URLs would then redirect the users to another website which required from them to provide their personal and financial information, consequently, stealing their data.

The company implemented measures to protect against distributed denial of service (DDoS) attacks, knowing the impact such attacks could have on its application's availability and user experience. In addition, the top management decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001.

III. The Implementation of the ISMS

After initiating the implementation of the ISMS, the company established the ISMS scope and the information security policy. In addition, Lenny, the project manager, undertook some activities to understand the company's context and conducted a gap analysis and a risk assessment. The risk assessment results, in particular, brought to light the root causes of the issues that were present.

Based on the findings, *e-Scooter* required from the Production Department of *LING* to design a more secure enclosure for the motherboard of the scooters, with no visible screws, making it challenging for malicious actors to tamper with the internal components, and to install more sensors to detect theft and damage to the scooters, further enhancing security. Moreover, to encourage responsible usage and accountability, *e-Scooter* urged its users to take a picture of their scooter after parking it and upload it through the application.

Another step that the company took was to have the scooters ping their location and relevant data (e.g., battery level) every 60 seconds to *e-Scooter*'s servers. To maintain an immutable record of each scooter's metadata, the data was securely stored in a private blockchain. The blockchain included information on the last user of the scooter, the duration of use, the route taken, and personal information, accessible only to authorized personnel within the company. To ensure the safety of the data in the blockchain in case of damages to its internal servers, *e-Scooter* decided to use a blockchain service offered by *NQS*. *NQS* provided an easy-to-build, scalable blockchain solution that enabled *e-Scooter* to easily implement a fast, centralized, immutable, and verifiable form of tracking its fleet of scooters.

In addition, *e-Scooter* implemented control 5.29 *Information security during disruption* from Annex A of ISO/IEC 27001 to enhance its ability to manage and recover from incidents, ensuring operational continuity and bolstering its overall resilience in the face of disruptions. Finally, to address the issue with the QR codes, the company decided to seal the QR codes behind a plastic layer so that the codes could no longer be removed.

As part of the ISMS implementation, *e-Scooter* conducted an internal audit, during which, the internal auditor examined the risk assessment process conducted by Lenny. The auditor reviewed the documented risk analysis and discussed the identified vulnerabilities with the Production Department of *LING*. The auditor considered that the company's response to the risk assessment results was adequate. Notably, *e-Scooter*'s decision to design a more secure enclosure for the motherboard and implement additional sensors to prevent theft and damage showcased its dedication to addressing risks proactively. The internal auditor also assessed the effectiveness of the blockchain implementation, concluding that it provided an extra layer of protection against potential internal server damages.

Furthermore, the security measures put in place by the company to protect customer data, such as encouraging users to take pictures of parked scooters and sealing QR codes behind a plastic layer, demonstrated *e-Scooter*'s commitment to safeguarding customer interests and ensuring responsible usage.

While evaluating the company's training and awareness program, the internal auditor discovered that *e-Scooter* had provided information security training only to the software development team. The auditor believed that the lack of training and awareness activities for other employees could lead to significant vulnerabilities within the company's operations, such as employees being unsuccessful in preventing information security breaches or responding to cyberattacks.

IV. Information System Architecture and Network Description

e-Scooter has two servers in its internal network infrastructure. One is the DB server, which is used to store company data, such as information stored by the Human Resources Department, the Accounting Department, etc. The other server is used by the software development team to access the source code of the application's previous versions, as well as the code of the current version. Through this server, the software development team reviews the old code when adding new features and tests any code before launch.

e-Scooter also has two cloud servers. The main server is used to manage the application's back-end operations, handling the traffic generated by the users and storing user data. The other cloud server is the blockchain cloud server, which stores all information that is transmitted by the sensors of the scooters to the blockchain. This cloud blockchain service is offered by *NQS*, and it communicates with the internal development server of *e-Scooter* via an API interface.

The software development team in *e-Scooter* makes frequent changes to the development database, because it is used on a daily basis. When a final version of the application is ready to be tested with real data from the blockchain database, a request is made to the information security director for confirmation on using the data stored in the blockchain. The access to the data is given in a case-by-case basis as there is no established formal method. However, provided that certain maintenance changes are conducted on a daily basis, the developers do not require the information security director's approval. Such changes include updates to the final version of the application that do not have anything to do with the blockchain data.

As stated in the company's information security policy, the developers should frequently back their code up to the database. However, such practice is highly neglected by the development team. Once the application is tested, the approval from the chief technology officer is required before the new version of the application is uploaded to the cloud server. New versions of the application usually come with updates to the back end of the cloud server. When changes occur, the cloud server and its databases are shut down for up to 10 minutes. The users are notified that the application is under maintenance during that time span. These changes are made when the traffic of the application is the lowest, usually between 04:00 and 05:00 a.m.

Figure 1: Cloud Application Structure

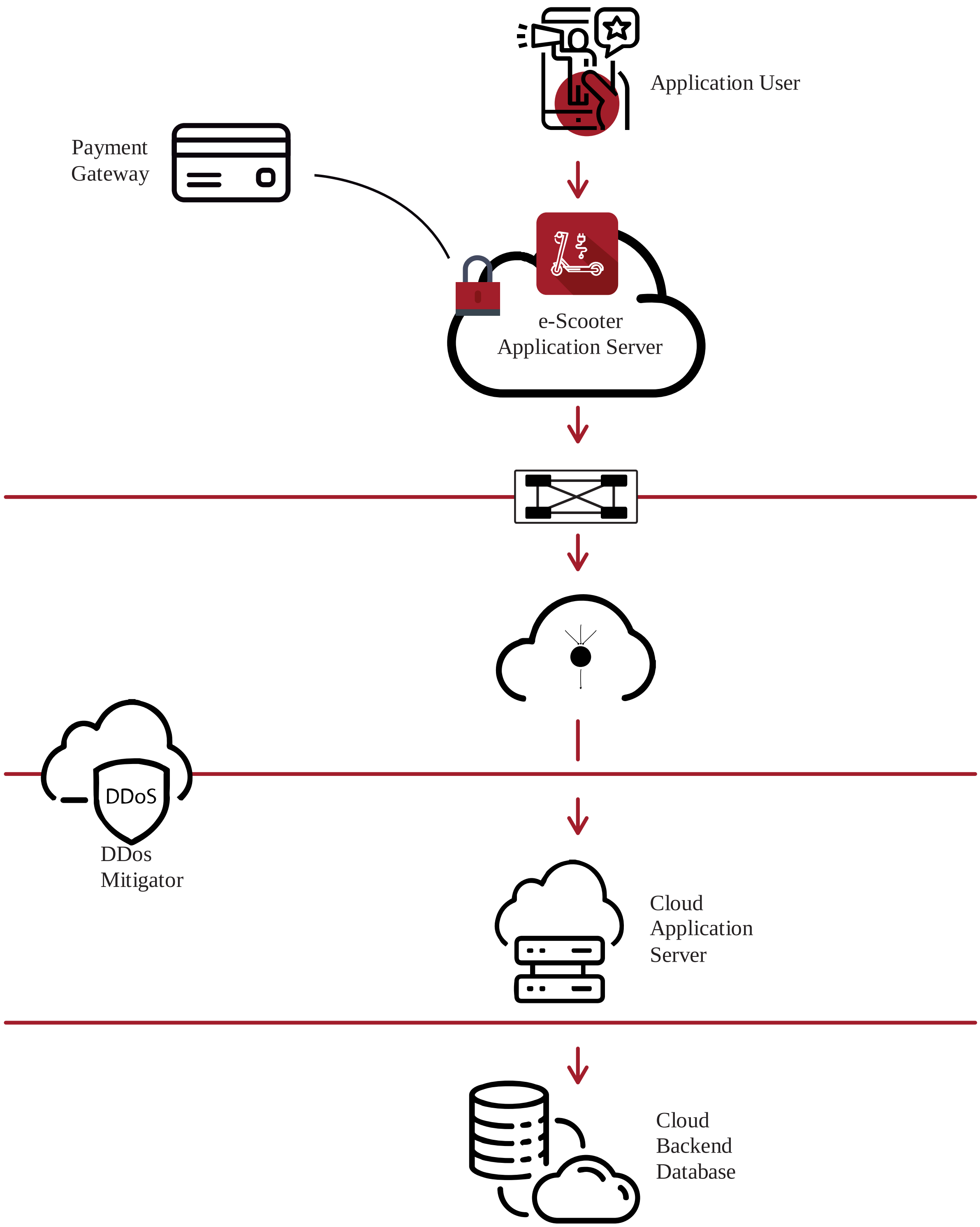

Figure 2: Local Infrastructure